

Penetration Testing Tutorial: What is PenTest?

What is Penetration Testing?

Penetration Testing is defined as a type of Security Testing (/what-is-security-testing.html), used to test the insecure areas of the system or application.

The goal of this testing is to find all the security vulnerabilities that are present in the system being tested. Vulnerability is the risk that an attacker can disrupt or gain authorized access to the system or any data contained within it. It is also called pen

testing or pen test.



(/images/SoftwareVulnerable.jpg).

Vulnerabilities are usually introduced by accident during software development and implementation phase. Common vulnerabilities include design errors, configuration errors, software bugs etc. Penetration Analysis depends upon two mechanisms namely Vulnerability Assessment and Penetration Testing(VAPT)

Why Penetration Testing?

Penetration is essential in an enterprise because -

- Financial sectors like Banks, Investment Banking, Stock Trading Exchanges want their data to be secured, and penetration testing is essential to ensure security
- In case if the software system is already hacked and the organization wants to determine whether any threats are still present in the system to avoid future hacks.

- Proactive Penetration Testing is the best safeguard against hackers

Types of Penetration Testing:

The type of penetration test selected usually depends on the scope and whether the organization wants to simulate an attack by an employee, Network Admin (Internal Sources) or by External Sources. There are three types of Penetration testing and they are

- [Black Box Testing \(/black-box-testing.html\)](#).
- White Box Penetration testing
- Grey Box Penetration Testing

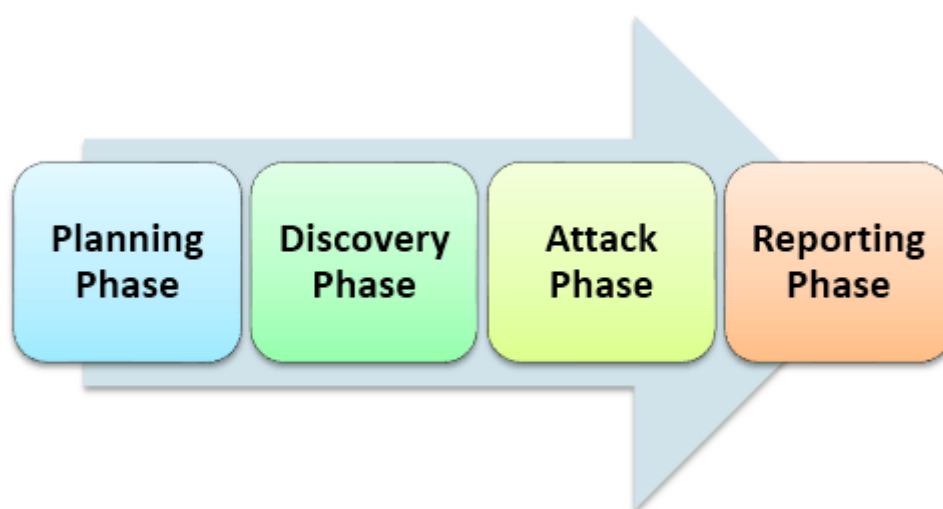
In black-box penetration testing, a tester has no knowledge about the systems to be tested. He is responsible to collect information about the target network or system.

In a white-box penetration testing, the tester is usually provided with complete information about the network or systems to be tested including the IP address schema, source code, OS details, etc. This can be considered as a simulation of an attack by any Internal sources (Employees of an Organization).

In a grey box penetration testing, a tester is provided with partial knowledge of the system. It can be considered as an attack by an external hacker who had gained illegitimate access to an organization's network infrastructure documents.

How to do Penetration Testing

Following are activities needs to be performed to execute Penetration Test -



[./images/PenetrationSteps.png](#)

Step 1) Planning phase

1. Scope & Strategy of the assignment is determined
2. Existing security policies, standards are used for defining the scope

Step 2) Discovery phase

1. Collect as much information as possible about the system including data in the system, usernames and even passwords. This is also called as **FINGERPRINTING**
2. Scan and Probe into the ports
3. Check for vulnerabilities of the system

Step 3) Attack Phase

1. Find exploits for various vulnerabilities You need necessary security Privileges to exploit the system

Step 4) Reporting Phase

1. A report must contain detailed findings
2. Risks of vulnerabilities found and their Impact on business
3. Recommendations and solutions, if any

The prime task in penetration testing is to gather system information. There are two ways to gather information -

- 'One to one' or 'one to many' model with respect to host: A tester performs techniques in a linear way against either one target host or a logical grouping of target hosts (e.g. a subnet).

- 'Many to one' or 'many to many' model: The tester utilizes multiple hosts to execute information gathering techniques in a random, rate-limited, and in non-linear.

Examples of Penetration Testing Tools

There is a wide variety of tools that are used in penetration testing and the important tools are:

1. NMap (<http://www.nmap.org/>):- This tool is used to do port scanning, OS identification, Trace the route and for Vulnerability scanning.
2. Nessus (<http://www.nessus.org/>):- This is traditional network-based vulnerabilities tool.
3. Pass-The-Hash - This tool is mainly used for password cracking.

Role and Responsibilities of Penetration Testers:

Penetration Testers job is to:

- Testers should collect required information from the Organization to enable penetration tests
- Find flaws that could allow hackers to attack a target machine
- Pen Testers should think & act like real hackers albeit ethically.
- Work done by Penetration testers should be reproducible so that it will be easy for developers to fix it
- Start date and End date of test execution should be defined in advance.
- A tester should be responsible for any loss in the system or information during the Software Testing
- A tester should keep data and information confidential

Manual Penetration vs. automated penetration testing:

Manual Penetration Testing	Automated Penetration Testing
<u>Manual Testing</u> (/manual-testing.html). requires expert professionals to run the tests	Automated test tools provide clear reports with less experienced professionals

Manual Testing requires Excel and other tools to track it	Automation Testing (/automation-testing.html) has centralized and standard tools
In Manual Testing, sample results vary from test to test	In the case of Automated Tests, results do not vary from test to test
Memory Cleaning up should be remembered by users	Automated Testing will have comprehensive cleanups.

Disadvantages of Penetration Testing

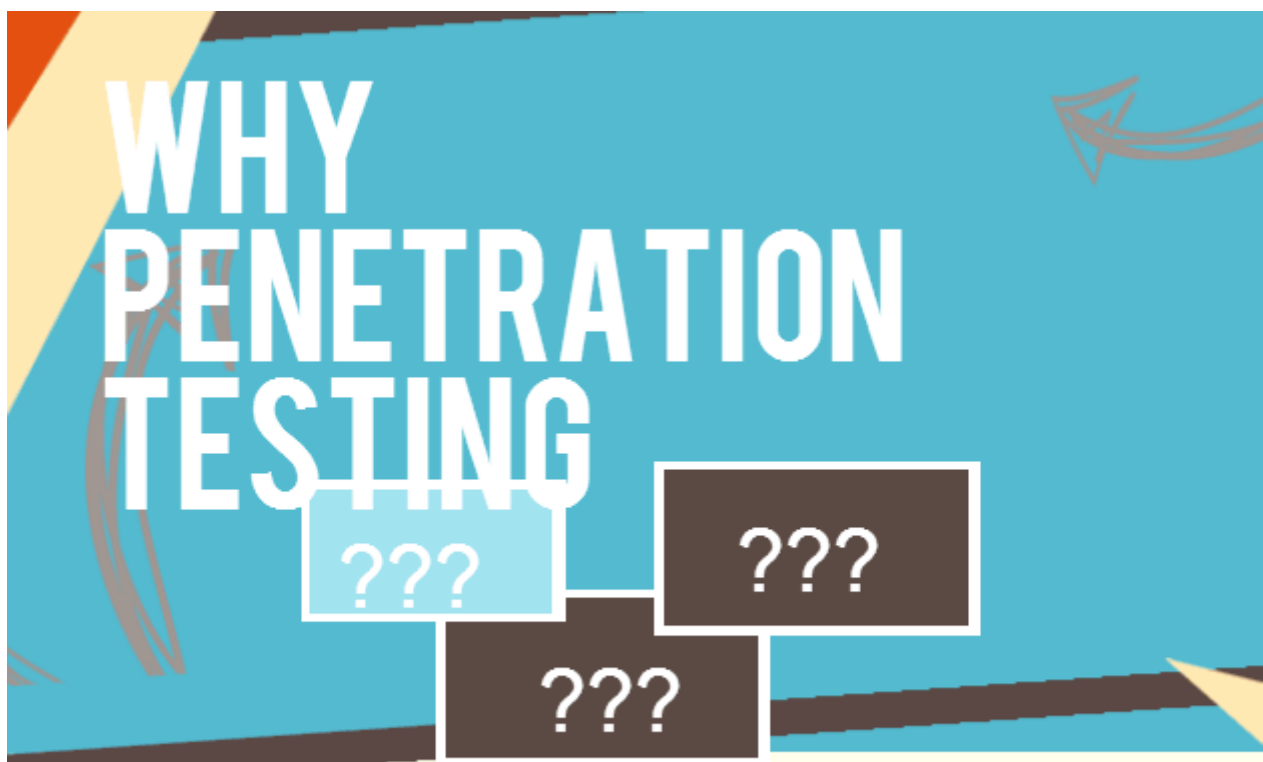
Penetration Testing cannot find all vulnerabilities in the system. There are limitations of time, budget, scope, skills of Penetration Testers

Following will be side effects when we are doing penetration testing:

- Data Loss and Corruption
- Down Time
- Increase Costs

Conclusion:

Testers should act like a real hacker and test the application or system and needs to check whether a code is securely written. A penetration test will be effective if there is a well-implemented security policy. Penetration testing policy and methodology should be a place to make penetration testing more effective. This is a complete beginners guide for Penetration Testing.



7400+ NEW VULNERABILITIES DISCOVERED EVERY YEAR

92%



VULNERABILITIES CAN BE
EXPLOITED REMOTELY

55%



ATTACKS AFFECT WEB
APPLICATIONS

74%



VULNERABILITIES DO NOT
HAVE A VENDOR PATCH BY
END OF YEAR

TOP WEB ATTACK VECTORS



Browser ■
Social Engineering ■
SQL Injection ■
Flash ■
Web 2.0 ■
ActiveX ■



EVEN MOST SECURE ORGANIZATIONS ARE NOT SECURE

**6.5 Million LinkedIn Passwords 'Leaked'
Online**

**World Bank Hacked, Sensitive Data
Exposed**

Hacked Web servers, a stolen administrative account, and lot of unanswered
questions

**TJX breach could top 94
million accounts**

Filings in case involving Visa cards alone as much as \$83 million

**Sony Admits Another Hacker Attack,
24.6 Million User Accounts
Compromised**

Guru99.com

(./images/WhyPenetrationTesting1.png)

Check our [Live Penetration Testing Project \(/live-penetration-testing-project.html\)](http://live-penetration-testing-project.html).



Guru99 is Sponsored by Acunetix



Acunetix, the developers of dead-accurate web application security scanners have sponsored the Guru99 project to help scan for over 4500 web vulnerabilities accurately and at top speed.

[VISIT THE ACUNETIX WEBSITE](https://bit.ly/2YIKeMV)

<https://bit.ly/2YIKeMV>

Testing Tutorials

[Quality Assurance \(/all-about-quality-assurance.html\)](/all-about-quality-assurance.html).

[Quality Management Plan Template \(/quality-management-plan-template.html\)](/quality-management-plan-template.html).

[SOA Testing \(/learn-soa-testing.html\)](/learn-soa-testing.html).

[Grey Box Testing \(/grey-box-testing.html\)](/grey-box-testing.html).

[ModelBased Testing \(/model-based-testing-tutorial.html\)](/model-based-testing-tutorial.html).

[Penetration Testing \(/learn-penetration-testing.html\)](/learn-penetration-testing.html).

[Compatibility Testing \(/compatibility-testing.html\)](/compatibility-testing.html).

[Pilot Testing \(/pilot-testing.html\)](/pilot-testing.html).

[Orthogonal Array Testing \(/orthogonal-array-testing.html\)](/orthogonal-array-testing.html).

[System Integration Testing \(/system-integration-testing.html\)](/system-integration-testing.html).

[Test coverage Testing \(/test-coverage-in-software-testing.html\)](/test-coverage-in-software-testing.html).

